Richtlinie zur koordinierten Offenlegung von Schwachstellen

Wie Sie uns Sicherheitslücken in Produkten und Diensten von NexAI melden – und was danach passiert

Stand: Oktober 2026 · Fassung 1.0

Entwurf – von NexAI erstellt, anwaltliche Prüfung folgt. Angaben in eckigen Klammern sind vor der Veröffentlichung zu bestätigen oder zu ergänzen.

1. Worum es geht

Die **NexAI – Next Generation Artificial Intelligence GbR**, Untere Bergstraße 13, 74586 Frankenhardt-Honhardt (nachfolgend „NexAI“), nimmt Hinweise auf Schwachstellen ernst. Diese Richtlinie beschreibt, wie Sie uns eine Schwachstelle melden, welche Regeln für Ihre Prüfung gelten, wie wir mit Ihrer Meldung umgehen und wann wir sie veröffentlichen.

Sie ist zugleich unsere Strategie für die koordinierte Offenlegung von Schwachstellen nach Anhang I Teil II Nr. 5 der Cyberresilienz-Verordnung (Verordnung (EU) 2024/2847, nachfolgend „CRA“). Die Belege stehen in Ziffer 10.

2. Geltungsbereich

(1) **Produkte:** das **NexAI CRM** mit Kauflizenz (Betrieb auf Servern des Kunden) in jeder Version, deren Unterstützungszeitraum noch läuft, sowie Apps, die NexAI in App-Stores bereitstellt [sobald veröffentlicht], einschließlich der von NexAI betriebenen Serverdienste, die diese Apps für ihre Funktion benötigen.

(2) **Dienste:** die von NexAI selbst betriebenen Anwendungen und Agenten, insbesondere unter nex-a-i.com und deren Subdomains (z. B. Website, Kundenportal, CRM im Betrieb durch NexAI, Kalender, E-Mail-Assistent, Telefon- und Chat-Agenten). Für diese Dienste wendet NexAI diese Richtlinie freiwillig in gleicher Weise an.

(3) **Nicht erfasst** sind Dienste Dritter, die NexAI nutzt (z. B. Hosting-, Telefonie- oder KI-Anbieter). Schwachstellen dort melden Sie bitte direkt dem jeweiligen Anbieter; betrifft eine solche Schwachstelle zugleich unsere Produkte, informieren Sie uns gern zusätzlich. Ebenfalls nicht erfasst sind Anliegen ohne Sicherheitsbezug (Bedienfragen, Störungen, Wünsche) – dafür ist der Support unter mbt@nex-a-i.com zuständig.

3. So melden Sie eine Schwachstelle

Unsere **zentrale Anlaufstelle** für Schwachstellen erreichen Sie auf folgenden Wegen:

- **E-Mail:** security@nex-a-i.com [bis zur Einrichtung dieses Postfachs: mbt@nex-a-i.com] – bevorzugter Weg;
- **Telefon:** 0176 80714816, Montag bis Freitag von 09:00 bis 17:00 Uhr; wir fassen das Gespräch anschließend schriftlich zusammen und senden es Ihnen zur Bestätigung;
- **Post:** NexAI – Next Generation Artificial Intelligence GbR, Stichwort „Schwachstelle“, Untere Bergstraße 13, 74586 Frankenhardt-Honhardt;

- **verschlüsselt:** [OpenPGP-Schlüssel mit Fingerabdruck – noch nicht eingerichtet]. Bis dahin senden Sie bitte zuerst nur eine kurze Erstmeldung ohne Ausnutzungsdetails; wir vereinbaren dann mit Ihnen einen sicheren Übertragungsweg.

Sie wählen den Weg, der Ihnen am besten passt. Anonyme Meldungen sind möglich. Dieselben Angaben finden Sie maschinenlesbar unter https://nex-a-i.com/.well-known/security.txt.

Was Ihre Meldung enthalten sollte

- das betroffene Produkt oder den Dienst, die Version bzw. die Internetadresse und den Zeitpunkt Ihrer Beobachtung;
- eine Beschreibung der Schwachstelle und ihrer möglichen Auswirkungen;
- die Schritte, mit denen wir sie nachstellen können, gegebenenfalls mit Beweiscode (Proof of Concept) oder Bildschirmfotos;
- ob die Schwachstelle Ihres Wissens bereits ausgenutzt wird oder öffentlich bekannt ist;
- wie wir Sie erreichen und ob Sie in einem Sicherheitshinweis namentlich genannt werden möchten.

4. Regeln für Ihre Prüfung

- Prüfen Sie nur so weit, wie es zum Nachweis der Schwachstelle nötig ist. Greifen Sie auf fremde Daten nicht weiter zu als dafür erforderlich, kopieren, verändern oder löschen Sie sie nicht und löschen Sie bereits eingesehene Daten nach Ihrer Meldung.
- Keine Angriffe auf die Verfügbarkeit (Denial of Service), kein Spam, keine Täuschung von Beschäftigten, Kunden oder Partnern (Social Engineering), keine physischen Angriffe.
- Bringen Sie keine Hintertüren oder Schadsoftware ein und geben Sie die Schwachstelle vor der Veröffentlichung nach Ziffer 7 nicht an Dritte weiter.
- Automatisierte Scans nur mit geringer Last.
- **Installationen bei Kunden:** Das NexAI CRM mit Kauflizenz läuft auf Servern unserer Kunden. Diese Systeme gehören nicht NexAI; dort darf nur mit Zustimmung des jeweiligen Betreibers geprüft werden. Für eigene Tests verwenden Sie bitte eine eigene Installation [Testzugang auf Anfrage].

5. Unsere Zusagen

NexAI bearbeitet jede Meldung unverzüglich. Dafür gelten folgende Richtwerte:

Schritt	Richtwert
Eingangsbestätigung	innerhalb von [3] Werktagen
Ersteinschätzung (bestätigt oder nicht, Schweregrad)	innerhalb von [10] Werktagen
Zwischenstand an Sie	mindestens alle [14] Tage bis zur Behebung
Behebung bei Schweregrad kritisch (CVSS 9,0–10,0)	Ziel: [7] Tage nach Bestätigung
Behebung bei Schweregrad hoch (CVSS 7,0–8,9)	Ziel: [30] Tage nach Bestätigung
Behebung bei Schweregrad mittel (CVSS 4,0–6,9)	Ziel: [90] Tage nach Bestätigung
Behebung bei Schweregrad niedrig (CVSS 0,1–3,9)	mit der nächsten regulären Version

Die Ziele sind Richtwerte, keine vertraglich zugesagten Fristen. Maßgeblich bleibt, dass NexAI Schwachstellen unverzüglich behandelt und Sicherheitsaktualisierungen unverzüglich und kostenlos verbreitet (Anhang I Teil II Nr. 2 und 8 CRA).

- Wir halten Sie über den Stand auf dem Laufenden und stimmen den Zeitpunkt der Veröffentlichung mit Ihnen ab.
- Steckt die Schwachstelle in einer Komponente eines Dritten (z. B. einer quelloffenen Bibliothek), melden wir sie auch dessen Hersteller oder Betreuer (Art. 13 Abs. 6 CRA).
- Wir zahlen keine Prämien (kein Bug-Bounty-Programm). Auf Wunsch danken wir Ihnen namentlich im Sicherheitshinweis.

6. Rechtssicherheit für Meldende

(1) Wer in gutem Glauben eine Schwachstelle sucht, sie meldet und sich dabei an Ziffer 4 hält, handelt in unserem Sinn. NexAI stellt in diesem Fall **keinen Strafantrag** und macht **keine zivilrechtlichen Ansprüche** gegen Sie geltend.

(2) NexAI kann Behörden und Dritte nicht binden. Das Ausspähen von Daten (§ 202a StGB) wird zwar grundsätzlich nur auf Antrag verfolgt, die Strafverfolgungsbehörde kann aber wegen eines besonderen öffentlichen Interesses auch von Amts wegen einschreiten (§ 205 Abs. 1 Satz 2 StGB). Für Systeme unserer Kunden und anderer Dritter können wir keine Erlaubnis erteilen.

(3) Sind Sie unsicher, ob eine Prüfung noch von dieser Richtlinie gedeckt ist, fragen Sie uns bitte vorher.

7. Koordinierte Veröffentlichung

(1) Bitte veröffentlichen Sie Einzelheiten zur Schwachstelle erst, wenn eine Sicherheitsaktualisierung bereitsteht und die Nutzer Gelegenheit hatten, sie einzuspielen – spätestens aber [90] Tage nach Ihrer Meldung, sofern wir nichts anderes vereinbaren. Wird die Schwachstelle bereits aktiv ausgenutzt, stimmen wir mit Ihnen einen kürzeren Zeitplan ab.

(2) Sobald eine Sicherheitsaktualisierung bereitgestellt ist, veröffentlicht NexAI einen **Sicherheitshinweis** mit Beschreibung der Schwachstelle, den betroffenen Produkten und Versionen, den Auswirkungen, dem Schweregrad und den Schritten zur Behebung unter [https://nex-a-i.com/de/sicherheit] (Anhang I Teil II Nr. 4 CRA). In hinreichend begründeten Fällen kann NexAI die Veröffentlichung aufschieben, bis die Nutzer die Aktualisierung einspielen konnten.

(3) Kunden, deren Installation betroffen ist, informiert NexAI zusätzlich direkt, bei einer aktiv ausgenutzten Schwachstelle einschließlich der Maßnahmen, die sie selbst ergreifen können (Art. 14 Abs. 8 CRA).

(4) Bei Bedarf beantragt NexAI für die Schwachstelle eine CVE-Kennung.

8. Meldungen an Behörden

(1) Erfährt NexAI von einer **aktiv ausgenutzten Schwachstelle** in einem Produkt im Sinne des CRA, meldet NexAI sie über die einheitliche Meldeplattform der ENISA gleichzeitig dem Bundesamt für Sicherheit in der Informationstechnik (BSI) als koordinierendem CSIRT und der ENISA (Art. 14 Abs. 1 und 7 CRA). Ihren Namen geben wir dabei nur mit Ihrer Zustimmung an.

(2) Sie können eine Schwachstelle auch selbst dem BSI melden. Das BSI nimmt solche Meldungen entgegen, auch anonym (§ 5 Abs. 2 BSIG), und gibt sie zur Schließung an den Hersteller weiter

(§ 5 Abs. 3 BSIG). Freiwillige Meldungen an ein koordinierendes CSIRT oder an die ENISA sieht auch Art. 15 CRA vor.

9. Datenschutz

Ihre Angaben verarbeiten wir nur, um die Meldung zu bearbeiten, mit Ihnen zu kommunizieren und unsere gesetzlichen Melde- und Dokumentationspflichten zu erfüllen. Rechtsgrundlage ist Art. 6 Abs. 1 lit. f DSGVO (berechtigtes Interesse an der Sicherheit unserer Produkte und Dienste) und, soweit eine gesetzliche Meldepflicht besteht, Art. 6 Abs. 1 lit. c DSGVO. Die technische Beschreibung der Schwachstelle bewahren wir als Teil der Produktdokumentation auf (Art. 13 Abs. 7 und 13 CRA). Ihre Kontaktdaten löschen wir [12 Monate] nach Abschluss des Vorgangs, es sei denn, Sie möchten in einem Sicherheitshinweis genannt werden. Im Übrigen gilt unsere Datenschutzerklärung unter https://nex-a-i.com/de/privacy.

10. Rechtlicher Rahmen (Belege)

Pflicht	Fundstelle	Wortlaut (Auszug)
Strategie zur koordinierten Offenlegung	Anhang I Teil II Nr. 5 CRA; Art. 13 Abs. 8 UAbs. 6 CRA	„eine Strategie für die koordinierte Offenlegung von Schwachstellen aufstellen und umsetzen“
Kontaktadresse für Schwachstellen	Anhang I Teil II Nr. 6 CRA	„… u. a. eine Kontaktadresse für die Meldung der in dem Produkt mit digitalen Elementen entdeckten Schwachstellen angeben“
Zentrale Anlaufstelle, Wahl des Kommunikationsmittels	Art. 13 Abs. 17 CRA	„… wobei diese Mittel nicht auf automatisierte Instrumente beschränkt werden dürfen“
Veröffentlichung nach Behebung	Anhang I Teil II Nr. 4 CRA	„sobald eine Sicherheitsaktualisierung bereitgestellt worden ist, Informationen über beseitigte Schwachstellen teilen und veröffentlichen“
Schwachstellen in Fremdkomponenten	Art. 13 Abs. 6 CRA	„… meldet er die Schwachstelle der Person oder Einrichtung, die diese Komponente herstellt oder wartet“
Meldepflicht bei aktiver Ausnutzung	Art. 14 Abs. 1 CRA; Art. 71 Abs. 2 UAbs. 2 CRA	„Artikel 14 gilt jedoch ab dem 11. September 2026“
BSI als Koordinator	§ 5 Abs. 1 Satz 2 BSIG	„Das Bundesamt ist dabei der nationale Koordinator für die Zwecke einer koordinierten Offenlegung von Schwachstellen …“

Fundstellen: Verordnung (EU) 2024/2847, konsolidierte Fassung vom 20.11.2024 (EUR-Lex, CELEX 02024R2847-20241120; laut CELLAR am 18.10.2026 die neueste konsolidierte Fassung); BSIG in der Fassung nach Art. 4 G v. 11.3.2026; StGB und DSGVO in der am 18.10.2026 geltenden Fassung.